Q&A Personal Data Protection Manual and Templates

Introduction

In September 2022 various Privacy Champions of Interogo Holding AG and its direct and indirect subsidiaries attended a training session hosted by DLA Piper about the use of the Personal Data Protection Manual and Templates ("Manual") and about the General Data Protection Regulation. After using the Manual in practice, certain questions arose which are answered below.

This Q&A document is designed to help those who are tasked with implementing data protection compliance.

Where we use the term "Group Company", we refer to the relevant direct or indirect subsidiary of Interogo Holding AG.

If you have any questions that are not listed below, please send an email to privacy@interogoholding.com.

Contents

Q&A Personal Data Protection Manual and Templates 1
Introduction 1
Q&A 4
1 Use of Manual & Templates 4
i Q: Can we obtain the templates as separate documents? 4
ii Q: Is the local supervisory authority the same as the data protection authority? 4
iii Q: On page 82, no link is included in point 8 – is this correct? 4
iv Q: What is the difference between special category data and sensitive data? 4
2 Data Protection Impact Assessment Checklist 4
3 Data Processing Agreement Decision tree 7
4 Transfer Impact Assessment Decision tree 9
5 IT Monitoring Policy 11
i Q: When can we expect the IT Monitoring Policy to be released? 11
6 Data breaches 11
i Q: I have sent an email containing personal data to a colleague, but I realize it has not gone to the correct recipient. What should I do? 11
ii Q: When should a personal data breach be notified to the data protection authority? 11
iii Q: What if a data breach is very minor? 12
iv Q: When should a personal data breach be notified to the data subjects involved and how? 12
v Examples of when to notify the regulator and/or data subject(s) 15

7 Language 17
i Q: The language of the manual is English. Is this the acceptable language in all the situations relevant to this manual? 17
ii You know that in Belgium, for an employment contract (and for any communication to employees) this has to be done in the language where the office is located (i.e. for Waterloo, it is French, for Brussels, it is French or Dutch at the employee's choice, for Leuven it would be Dutch). Can we use the English version of the DPA for the DPAs to be signed our suppliers? 17
8 New systems/projects 17
i Q: We are launching a new system which uses the names of all Group Company employees. Which documents need to be completed? Who can help me with the process? 17
9 Cookie notice 17
i Q: Is a cookie notice required if the website uses plausible.io software which does not place cookies? 17
10 Controller-to-Controller Clause 18
i Q: Could you give typical examples when a controller-to-controller clause should be implemented? You mention that one such example is when lawyers are engaged. Does this mean that when we work with a law firm specialised in employment law, we should include a controller-to-controller clause unless such a data protection clause is already included in the contract which offers the same safeguards as the controller-to-controller template clause? Does this also apply with all our suppliers? 18
ii Q: What suppliers are typically considered separate controllers? 18
11 Data subject rights 19
i Q: Where can the Privacy files spreadsheet be found as referenced in the data subject rights response procedure? 19
ii Q: In section 8b of the Template Data Subject Rights Response Procedure it states: "Upon receipt of the required documents, the person receiving the request will provide the Personal data champion(s) with all relevant information in support of the DSR. In case the information provided meets the expectations, the PC(s) will notify the requestor that his/her DSR will be responded to within 30 calendar days or handle the request immediately." 1. What is meant with expectations, expectation of whom, defined by whom? & 2. Who makes the decision how to respond to the data subject request? 19
12 Privacy Notices 19
i Q: When should we share a privacy notice with the data subject? For instance, when working with a recruitment company, at what stage should the applicant receive our privacy notice? 19
ii Q: Is there a general privacy notice? 20
iii Q: The privacy statement (https://vastint.eu/privacy-statement/) is written for the Netherlands and does not reflect clearly the fact that each Vastint entity is a separate controller. How shall this be amended and fixed? 20
iv Q: What privacy notices shall be disclosed on the websites for visitors who are neither applicants nor co-workers? 20
13 Standard Contractual Clauses (SCCs) 20
i Q: What is the purpose of the docking clause? 20
ii Q: Do we require a copy of the Module 3 SCCs? 20
iii Q: Can we amend the wording of the SCCs? For instance, would it be possible to replace "at regular intervals' with "when a data breach occurs or when a data subject submits a question to the data importer"? in clause 15.1 (h) on page 232. 20
iv Q: What is the difference between data importer vs. data processor or data controller. 20
14 Contact details from local law firms 21

15 Amendments to Manual & Templates for the creation of version 2.0 22

Q&A

1 Use of Manual & Templates

i Q: Can we obtain the templates as separate documents?

A: Yes, this is possible. Please double click on the attachments that are included in the right-hand corner in the Manual, pages 5-22. By clicking the attachment, you directly download the template as a separate file.

ii Q: Is the local supervisory authority the same as the data protection authority?

A: Yes.

iii Q: On page 82, no link is included in point 8 – is this correct?

A: Yes. This is correct as this should be included by the specific Group Company when implementing this procedure. The procedure should be personalized and aligned with the specific internal processes of the Group Company that implements the procedure.

iv Q: What is the difference between special category data and sensitive data?

A: When we use the term “special category data” we are referring to data categories which have special protections under European data protection law. “Special category data” are personal data relating to race or ethnicity, political opinions, religious or philosophical beliefs, trade union membership. It also includes genetic data, biometric data (when used to identify someone), health data, and data about a person's sex life or sexual orientation.

Personal data relating to criminal convictions and offenses also have a special status under European data protection law. For the purposes of this manual and other compliance documentation, we include personal data relating to criminal convictions and offenses when we refer to “special category data”.

When we use the term “sensitive data” we mean any other data that is not officially considered special category data under European data protection law but may have a greater impact on the rights of individuals than other ordinary personal data. at the level of a Group Company this includes financial data, citizen service numbers/identification numbers, or passport information.

2 Data Protection Impact Assessment Checklist

A Data Protection Impact Assessment (“DPIA”) is required if a processing activity is likely to result in high risks to the rights and freedoms of the data subjects involved. You can use the below checklist to help identify whether you need to conduct a DPIA for your processing activity.

☐ Do any of the following processing activities apply?

(a) The processing of personal data involves systematic and extensive evaluation of personal aspects which is based on automated processing (including profiling[1]) with significant effects for the data subject concerned

- *Example: automated assessment and scoring of candidates for an open position*

(b) The processing of personal data involves a large scale of special categories or criminal convictions or offences

- *Example: conducting background checks for all new employees in a particular group function*

(c) The processing of personal data involves a systematic/constant monitoring of a publicly accessible area on a large scale[2]

- *Example: the use of CCTV cameras on the outside of our premises (see also at page 14 of the Manual)*

If, your response is "yes" to any of the above, then you must complete a DPIA for your processing activity.

If, your response is "no" to all of the above, please continue to the next question.

☐ Do any of the below 'High risk' factors apply to your processing activity? My processing activity involves:

(a) Evaluation or scoring, including profiling[3] and predicting activities

- *Examples: anti-money laundering checks during a customer's due diligence process*

(b) Automated decision-making

- *Examples: an algorithm that recommends employees that are due for promotion based on their HR data*

(c) Systematic monitoring (i.e. processing used to observe, monitor or control data subjects, including data collected through public networks or via publicly accessible area)

- *Examples: use of CCTV cameras on the outside the premises (see page 14 of the Manual); data loss prevention measures which involve monitoring of employees' e-mails (see Annex 5 at page 40 of the Manual)*

---

1 Profiling is where personal data are processed automatically with the objective of assessing individual's personal aspects. For instance, where you analyze or predict aspects concerning an individual's work performance, health, behavior, interests, etc.

2 The GDPR does not define what constitutes large scale processing. However, it is generally understood to include scenarios such as a large volume of personal data, a large number of individuals whose data are processed, and/or data that is processed for a long-term or permanent basis. It can also include processing data relating to individuals across a large geographical area.

3 See footnote 1

(d) Sensitive data or data of a highly personal nature (i.e. special categories of personal data (e.g. health data, biometric data, trade union membership, etc.) or sensitive personal data (e.g. financial data)

- *Example: the processing of adjustments required in the workplace for employees with disabilities*

(e) Data processed on a large scale[4] (i.e. taking into account the number of data subjects concerned, the volume of data or range of different data, the duration or permanence of processing, the geographical extent)

- *Example: use of a mailing list to send a generic daily digest to subscribers; processing of hundreds of customer data*

(f) Matching or combining datasets

- *Example: collecting public social media data to generate customers profiles and targeted marketing communications*

- Data concerning vulnerable data subjects (i.e. personal data of children, employees[5], persons requiring a specific protection such as mentally ill persons or asylum seekers)Examples: use of GPS trackers in company cars that can be used for employees' private purposes, processing activities to detect and prevent employee departure based on correlations established between various factors

(g) Innovative use or applying new technological or organisational solutions

- *Example: generating a new tool or system that makes use of artificial intelligence*

(h) Processing activity aimed at preventing data subjects from exercising a right, or using a service or a contract

- *Example: use a customer's score to assess its access to certain services*

☐ If your processing activity meets two or more of the above “high risk” factors, then you should complete a DPIA for your processing activity.

☐ If your processing activity meets only one of the above “high risk” factors, then you can contact local counsel (**please include** radha.pulltergunne@dlapiper.com in cc) to discuss the approach. In rare situations a Group Company may choose to complete a DPIA even where only one “high risk” factor applies.

☐ If none of the “high risk” factors apply, then you do not need to complete a DPIA for your processing activity.

☐ See for further information page 18 of the Manual.

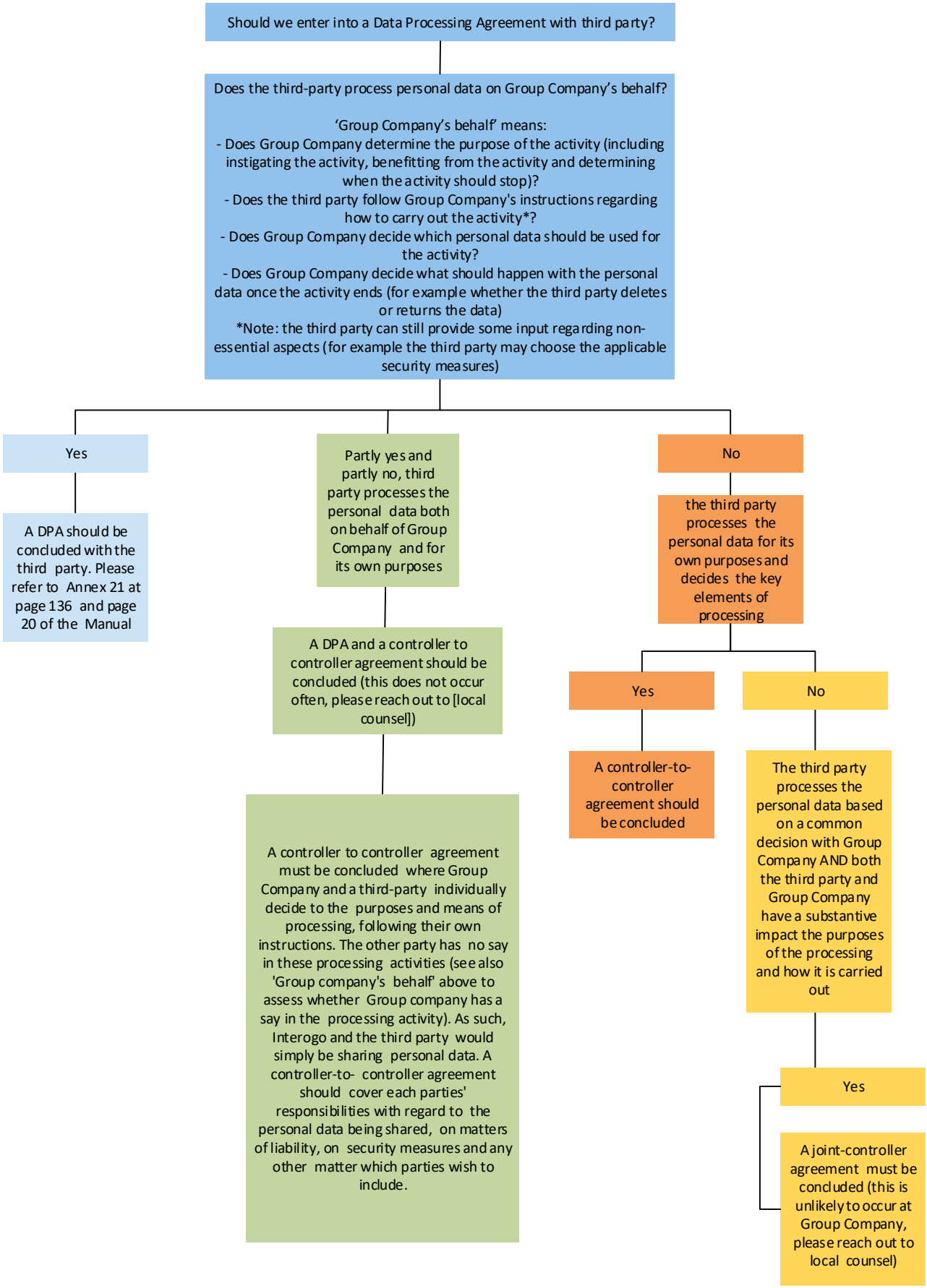
---

4 See footnote 2

5 According to the European Data Protection Board, employees are considered vulnerable data subjects due to the inherent power imbalance between the employer and employee.

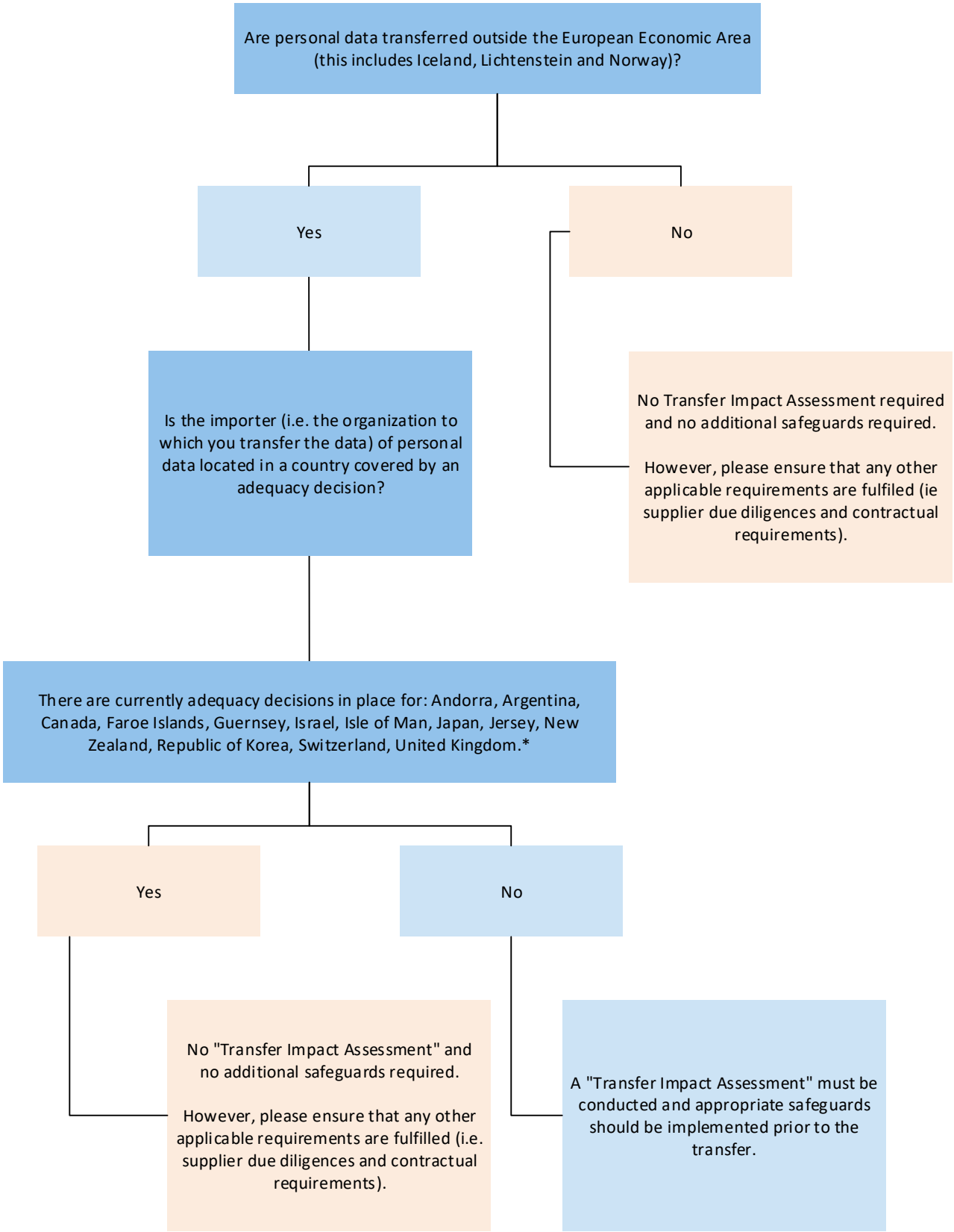
3 Data Processing Agreement Decision tree

Data Protection Laws require that a Data Processing Agreement ("DPA") is executed whenever an organization appoints a third-party processor. You can use the decision tree below to help decide whether the third party is a processing party and therefore whether you need to execute a DPA.


Should we enter into a Data Processing Agreement with third party?
Does the third-party process personal data on Group Company's behalf?
'Group Company's behalf' means:
- Does Group Company determine the purpose of the activity (including instigating the activity, benefitting from the activity and determining when the activity should stop)?
- Does the third party follow Group Company's instructions regarding how to carry out the activity*?
- Does Group Company decide which personal data should be used for the activity?
- Does Group Company decide what should happen with the personal data once the activity ends (for example whether the third party deletes or returns the data)
*Note: the third party can still provide some input regarding non-essential aspects (for example the third party may choose the applicable security measures)
Yes
A DPA should be concluded with the third party. Please refer to Annex 21 at page 136 and page 20 of the Manual
Partly yes and partly no, third party processes the personal data both on behalf of Group Company and for its own purposes
A DPA and a controller to controller agreement should be concluded (this does not occur often, please reach out to [local counsel])
A controller to controller agreement must be concluded where Group Company and a third-party individually decide to the purposes and means of processing, following their own instructions. The other party has no say in these processing activities (see also 'Group company's behalf' above to assess whether Group company has a say in the processing activity). As such, Interogo and the third party would simply be sharing personal data. A controller-to- controller agreement should cover each parties' responsibilities with regard to the personal data being shared, on matters of liability, on security measures and any other matter which parties wish to include.
No
the third party processes the personal data for its own purposes and decides the key elements of processing
Yes
A controller-to-controller agreement should be concluded
No
The third party processes the personal data based on a common decision with Group Company AND both the third party and Group Company have a substantive impact the purposes of the processing and how it is carried out
Yes
A joint-controller agreement must be concluded (this is unlikely to occur at Group Company, please reach out to local counsel)

4 Transfer Impact Assessment Decision tree

European Data Protection Law places additional requirements on organisations which send or otherwise make personal data available outside of the European Economic Area. You can use the decision tree below to help identify what steps you need to take for any transfers of personal data outside of your country.



* Please note that the EU Commission regularly reviews and updates its adequacy list. At the time of writing, it is expected that the EU Commission will soon grant the USA a form of adequacy status. Please refer to this website for the most updated list.

5 IT Monitoring Policy

i Q: When can we expect the IT Monitoring Policy to be released?

A: The final version is aimed to be communicated in Q3 after finalizing the Information Security Risk analysis and assessment in Q1/Q2. IT Monitoring will be a chapter in the Information Security Policy.

6 Data breaches

i Q: I have sent an email containing personal data to a colleague, but I realize it has not gone to the correct recipient. What should I do?

A: **Immediately** contact your local Privacy Champion. It does not matter whether it is a holiday, on the weekend or in the evening. It may be the case that this qualifies as a data breach, and if so, immediate action is necessary as it may be required to notify the local data protection authority which must occur within 72 hours.

If it is possible, please try to recall the email. Once you have informed the Privacy Champion you should wait for instructions before taking any further action.

Privacy Champions will assess the incident and gather any additional information needed. If necessary, the Privacy Champions will reach out to local counsel – see the list in section 14 below - (**and please include** radha.pulltergunne@dlapiper.com in cc) for support determining (i) whether it qualifies as a data breach, (ii) whether it should be notified to the relevant Data Protection Authority and (iii) whether it should be notified to the individuals affected by the breach. See below the data breach decision tree for additional guidance on the assessment to follow.

NB: Privacy Champions shall report serious privacy data breaches (any breaches which are likely to create high or medium risk for the data subjects and should be notified to the local Data Protection Authorities and /or to the data subjects) immediately and without delay to:

(i) the respective Group Company's Board by email

(ii) privacy@interogoholding.com

Non serious breaches (which are unlikely to result in high or medium risk for the data subjects) shall be flagged to the Group Companies' Directors at the upcoming Board meeting of the entity concerned.

At the end of each year, IHAG will collect reports for breaches of personal information which have occurred during the year in all Group Companies.

ii Q: When should a personal data breach be notified to the data protection authority?

A: A personal data breach should be notified where there is **likely to be a risk** to data subjects. In such a situation, the law requires Group Company to notify data breaches **within 72 hours** of becoming 'aware' of the data breach. This is why it is so important that you notify your local Privacy Champion as soon as possible.

iii Q: What if a data breach is very minor?

A: If a data breach is deemed "**unlikely to result in a risk** to the rights and freedoms of natural persons", a controller does not have to notify the data protection authority. In practice, this occurs when there will be no impact on the data subjects, or the likelihood and severity of any impact is negligible. For example, if an unauthorized employee has accidently been granted access to specific and limited HR files containing non-sensitive information and reported it internally immediately (including confirming in writing that they did nothing else with the personal data). In such a situation, the risks are very low and there is no need to notify such a breach. Please see below for additional examples.

Please note that if there is a more than negligible likelihood or severity of risk to the data subject, Group Company may need to make a notification to the relevant data protection authority. We provide some examples in the table below.

iv Q: When should a personal data breach be notified to the data subjects involved and how?

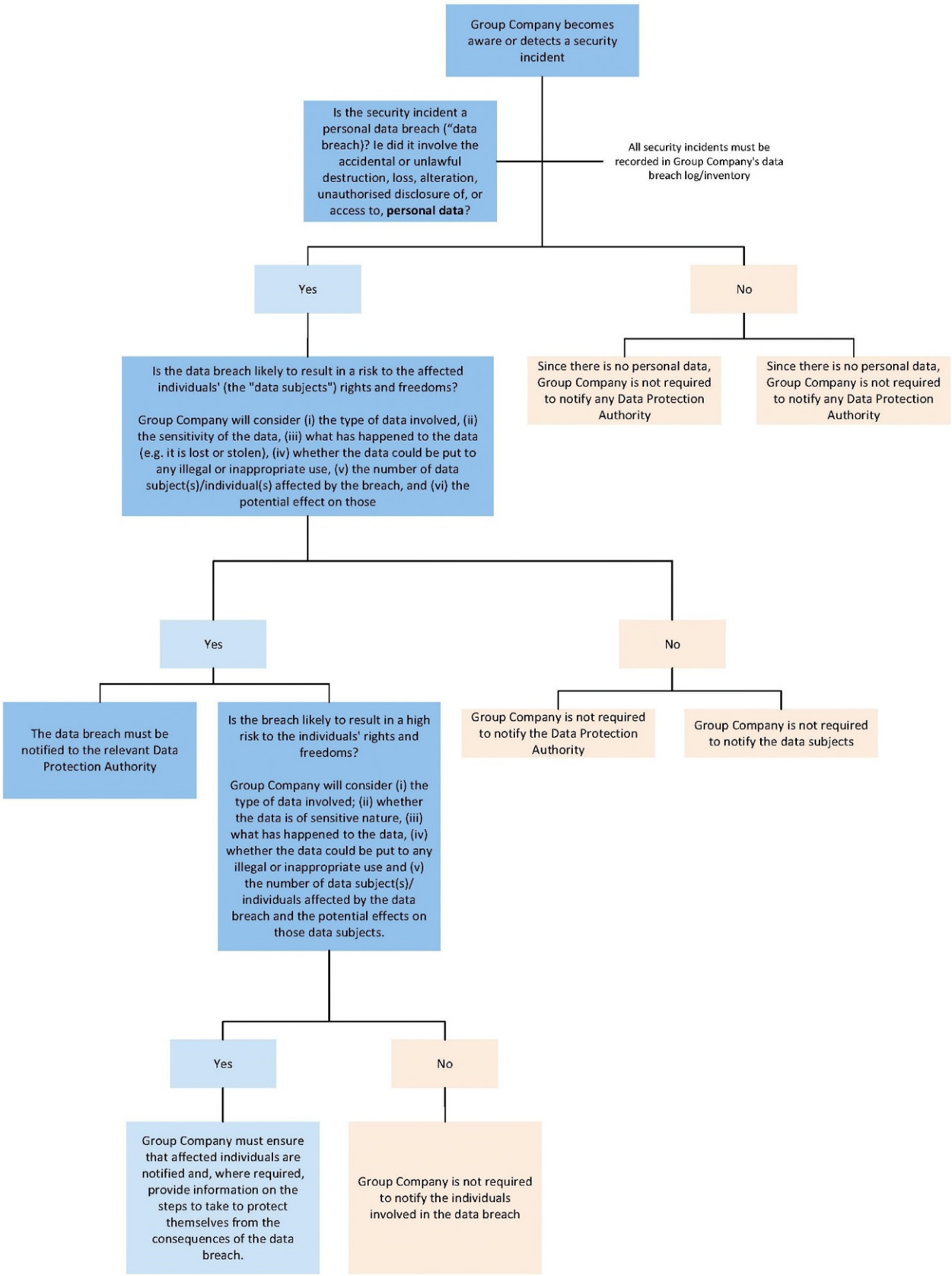
A: Individuals should be notified if a personal data breach is **likely to result in high risk** to data subjects. Individuals should be notified as soon as possible, in most cases, this means that Group Company should notify affected individuals within a few days, as a data protection authority may consider several weeks to be too long. “Risks to rights and freedoms” are examined by considering the following factors (see also p. 101 of the Manual and the slide deck of the training):

- The type of data involved;
- Whether the data is of sensitive nature (e.g. special category data such as health data or trade union membership, data relating to criminal offences (such as background checks), national identification numbers, or financial data);
- What has happened to the data (for example has it been lost or stolen);
- Whether the data could be put to any illegal or inappropriate use (e.g. ID-cards information or banking information from personnel files may be further used); and
- Number of data subject(s)/individuals affected by the Data Breach and the potential effects on those data subjects.

A data breach could be “high risk” when it may lead to physical, material and non-material damage to the individuals affected by the breach (such as discrimination, identity theft or fraud, financial loss and damage to reputation). A data breach is also likely to be “high risk” when it involves special category of data or sensitive data, since the above-mentioned types of damage are more likely to occur.

The threshold for communicating a breach to individuals is therefore higher than the threshold for communicating a breach to the data protection authority. The notification to affected persons must be made in addition to notification to the relevant data protection authority. Please see below for examples on when to notify individuals.

Please use below decision tree on when to notify the data protection authority and when to notify data subjects involved:


Group Company becomes aware or detects a security incident
Is the security incident a personal data breach ("data breach)? Ie did it involve the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, **personal data**?
All security incidents must be recorded in Group Company's data breach log/inventory
Yes
No
Since there is no personal data, Group Company is not required to notify any Data Protection Authority
Since there is no personal data, Group Company is not required to notify any Data Protection Authority
Is the data breach likely to result in a risk to the affected individuals' (the "data subjects") rights and freedoms?
Group Company will consider (i) the type of data involved, (ii) the sensitivity of the data, (iii) what has happened to the data (e.g. it is lost or stolen), (iv) whether the data could be put to any illegal or inappropriate use, (v) the number of data subject(s)/individual(s) affected by the breach, and (vi) the potential effect on those
Yes
No
The data breach must be notified to the relevant Data Protection Authority
Is the breach likely to result in a high risk to the individuals' rights and freedoms?
Group Company will consider (i) the type of data involved; (ii) whether the data is of sensitive nature, (iii) what has happened to the data, (iv) whether the data could be put to any illegal or inappropriate use and (v) the number of data subject(s)/ individuals affected by the data breach and the potential effects on those data subjects.
Group Company is not required to notify the Data Protection Authority
Group Company is not required to notify the data subjects
Yes
No
Group Company must ensure that affected individuals are notified and, where required, provide information on the steps to take to protect themselves from the consequences of the data breach.
Group Company is not required to notify the individuals involved in the data breach

v Examples of when to notify the regulator and/or data subject(s)

We provide some examples of when to notify the data protection authority and/or data subjects on page 99 of the Manual. Please find below additional examples. We further suggest reading and/or using when necessary the EDPB Guidelines 01/2021 for examples regarding personal data breach notification which provides cases with detailed explanation on whether or not to notify the Authority or Data Subjects. Please note, whenever a data breach (may) occur, always reach out to the Privacy Champion.

Case	Notification to the DPA?	Notification to data subjects?
Hack of personnel files containing sensitive data (e.g., IDs, financial data, data on sickness absence, etc.)	Yes, as this breach is likely to result in risks to the rights and freedoms of employees.	Yes, as the stealing of personal data from the personnel files poses a high risk to the rights and freedoms of employees. This takes into account the sensitivity of the data and the amount of data subjects involved.
Lost locked suitcase in a train containing Personal Data is located and returned with the lock unopened within 24 hours	No, as it is unlikely to result in risks to the rights and freedoms of the data subjects involved.	No, as it is unlikely to result in high risks.
Highly confidential Personal Data of 10 employees were accidentally sent to a customer. Multiple attempts were made to get in touch with this customer but they remain unanswered.	Yes, it is likely to result in risks to the rights and freedoms of individuals.	Yes, regarding the sensitivity of the personal data it is likely to result in high risks for these 10 employees.
Hack of a large amount of usernames and (encrypted/hashed) passwords from customers' accounts	If a customer's username is their e-mail address, then the DPA must be notified as there is a risk the hacker further uses this email address and password for other websites (i.e. credential stuffing). The risks are lower when an account is created with an arbitrary pseudonym and thus the chances are lower that the attacker will be able to use such pseudonym and password with another website.	No, as it is unlikely to result in high risks. However, we strongly recommend communicating the breach to the customers and advise them to change their password.

Case	Notification to the DPA?	Notification to data subjects?
Incorrect deletion of personal data of employees without proper backup	Yes, as this is likely to result in risks to the rights and freedoms of employees.	Depending on the employee, this may involve high risks. Such as for employees having been sick at several periods during the last few years and for which the insurance requires accurate records of leave of absence of such employees which were deleted. Or when such files included details on the accident having occurred at the work premises.
Business documents which include some Personal Data (i.e. name and surname of employees involved in project and their role during the project) were archived and encrypted on a USB key. The key is stolen during a break in. The data was encrypted with a state-of-the-art algorithm, other backupsexist, and the unique key is not compromised.	No, unless it still appears the data can easily be de-crypted. If that is the case, a notification is required.	No, as it is unlikely to result in high risks to the individuals affected.

7 Language

i Q: The language of the manual is English. Is this the acceptable language in all the situations relevant to this manual?

ii You know that in Belgium, for an employment contract (and for any communication to employees) this has to be done in the language where the office is located (i.e. for Waterloo, it is French, for Brussels, it is French or Dutch at the employee's choice, for Leuven it would be Dutch). Can we use the English version of the DPA for the DPAs to be signed our suppliers?

A: Some countries have local language requirements which will apply to documents published in that jurisdiction. This often means that documents that apply to employees and candidates in that jurisdiction have to be translated into local languages to ensure transparency obligations are met (for example any privacy notices). Nevertheless, this depends on local laws, and we recommend reaching out to local counsel if you are uncertain. Contact details are included in this document below.

When contracting with suppliers in a B2B environment, it is generally possible to use the English version of the DPA however in some countries there may be different market standards which Group Company wishes to adhere to.

8 New systems/projects

i Q: We are launching a new system which uses the names of all Group Company employees. Which documents need to be completed? Who can help me with the process?

A: Various documents may need to be implemented depending on the project, for instance:

- a data protection impact assessment (see the DPIA section (p. 18) and Annex 20 (p. 122) of the Manual and under section 2 of this Q&A);
- if a vendor is engaged, a data processing agreement (see the DPA Playbook (p. 20) and Annex 21 (p. 136) of the Manual) and under section 3 of this Q&A);
- an update to a privacy notice (see the Privacy for Co-Worker section (p. 9), Applicants (p. 10) and general (p. 11)); and/or
- an update to the Records of Processing Activities (see the Records of Processing Activities section (p. 7) and Annex 6 (p. 47) of the Manual).

If you need additional guidance, please reach out privacy@interogoholding.com)

9 Cookie notice

i Q: Is a cookie notice required if the website uses plausible.io software which does not place cookies?

A: It is not possible to provide an "yes" or "no" answer without reviewing the implementation of this software on the relevant website. Plausible i.o. states that their software ensures that site measurement is carried out anonymously. They state that

cookies are not used, and no personal data is collected, nor any persistent identifiers. Nevertheless, please note that cookies are not the only tracking technologies that can be used to track user behaviour online. Other types of technologies, such as pixels and SDKs also fall under the ePrivacy Directive (see page 70 of the Manual). In addition, IP-addresses and other device identifiers are considered personal data which means that if these are collected and, for instance, linked to website user behavior, a cookie notice is required. If you are considering using Plausible.io, please reach out to your local counsel (see contact list below) so they can provide additional analysis based on your website's information and functioning.

10 Controller-to-Controller Clause

i Q: Could you give typical examples when a controller-to-controller clause should be implemented? You mention that one such example is when lawyers are engaged. Does this mean that when we work with a law firm specialised in employment law, we should include a controller-to-controller clause unless such a data protection clause is already included in the contract which offers the same safeguards as the controller-to-controller template clause? Does this also apply with all our suppliers?

A: You are correct that many agreements generally already have a data protection clause included but it is important to compare the clause to the template controller-to-controller agreement included in the Manual to ensure the Group Company Holding Group entity is sufficiently protected.

However, the controller-to-controller clause cannot be used with all suppliers as some suppliers may process personal data on behalf of the Group Company Holding Group entity. In these situations, a data processing agreement may be required. Therefore, it is important to look at the service the supplier is providing and what personal data is involved and whether it is proportional. For instance, when concluding a contract with a supplier of coffee machines, no additional privacy clauses required.

Please look at the data processing agreement decision tree (at part 3 of this document) to support you with the assessment and to the question below for a few examples.

ii Q: What suppliers are typically considered separate controllers?

A: Those are suppliers that process personal data as part of their own processes, such as:

- A recruitment agency
- A postal service supplier
- An auditing firm.

To the extent that Group Company enters into service agreements with these organisations, Group Company should consider ensuring a controller-to-controller clause is in place.

11 Data subject rights

i Q: Where can the Privacy files spreadsheet be found as referenced in the data subject rights response procedure?

A: Please note this section is only an example of how an internal process can look like, as indicated by the comment included (it is a placeholder and should be amended to reflect internal processes). We have provided a template privacy files spreadsheet in version 2.0 of the Manual for your convenience.

ii Q: In section 8b of the Template Data Subject Rights Response Procedure it states: "Upon receipt of the required documents, the person receiving the request will provide the Personal data champion(s) with all relevant information in support of the DSR. In case the information provided meets the expectations, the PC(s) will notify the requestor that his/her DSR will be responded to within 30 calendar days or handle the request immediately." 1. What is meant with expectations, expectation of whom, defined by whom? & 2. Who makes the decision how to respond to the data subject request?

A: Please note this section is only an example of how an internal process can look like, as indicated by the comment included (it is a placeholder and should be amended to reflect internal processes).

When receiving a request, this request must be analysed. Does it adhere the required elements to be considered a data subject right request under the GDPR? For instance, did the data subject provide enough information so that a PC can adequately identify the requestor? Did the requestor indicate which of its rights it wants to enforce? The expectations are outlined in the GDPR and to be determined by the PC. The PC then notifies the requestor that the request will be actioned or not. The PC is also responsible for ensuring the notification to the requestor is in line with the GDPR. To aid the PC, we have provided template responses in Appendix 2 to the template procedure. If you require more in-depth guidance on data subject requests, we recommend you take a look at this document: edpb_guidelines_012022_right-of-access_0.pdf (europa.eu)

For more information on when you can reject a data subject request, please review the presentation slides.

12 Privacy Notices

i Q: When should we share a privacy notice with the data subject? For instance, when working with a recruitment company, at what stage should the applicant receive our privacy notice?

A: A privacy notice should be provided at the time when personal data are obtained. When working with a recruitment company, this company usually has their own privacy policy in place informing the applicants that personal data is collected and shared with their clients. The moment aGroup Company starts collecting personal data directly from the applicant because there is direct contact, for instance, when the interview phase has started, we recommend sharing a copy of the Group Company applicant privacy notice. This can be done by instructing the recruitment company to send a copy of the notice when they set up the interview or share the contact details.

ii Q: Is there a general privacy notice?

A: We will update the Manual to include a general/website privacy notice.

iii Q: The privacy statement (https://vastint.eu/privacy-statement/) is written for the Netherlands and does not reflect clearly the fact that each Vastint entity is a separate controller. How shall this be amended and fixed?

A: Manual 2.0 is updated to include a general/website privacy notice which caters for the fact that various entities in multiple countries will use the same privacy policy.

iv Q: What privacy notices shall be disclosed on the websites for visitors who are neither applicants nor co-workers?

A: A general/website privacy notice should be disclosed. Manual 2.0 is updated to include such a notice.

13 Standard Contractual Clauses (SCCs)

i Q: What is the purpose of the docking clause?

A: This is a clause to add additional parties to the SCCs. An entity that is not a Party to these Clauses may, with the agreement of the Parties, accede to these Clauses at any time, either as a data exporter or as a data importer, by completing the Appendix and signing Annex I.A. Please reach out to your local legal counsel (see the contact list below) if you need assistance.

ii Q: Do we require a copy of the Module 3 SCCs?

A: No, Module 3 SCCs apply to the situation where a Processor of a Group company engages a sub- processor. Signing Module 3 SCCs is an obligation for the Processor and is not something a Group Company must action as the Group Company is not part of the agreement. The reason Module 3 SCCs are mentioned in the DPA Negotiation Playbook is to provide background information to clause 11.3 of the template Data Processing Agreement.

iii Q: Can we amend the wording of the SCCs? For instance, would it be possible to replace "at regular intervals' with "when a data breach occurs or when a data subject submits a question to the data importer"? in clause 15.1 (h) on page 232.

A: It is not possible to amend the wording of the SCCs. These clauses are drafted by the European Commission, and it is only possible to rely on these clauses when they remain unaltered.

In addition, regarding the example, this amendment would not work because clause 15.1 (h) does not relate to data breaches or data subject requests but to requests from public authorities. Therefore, please do not amend the clauses of the SCCs.

iv Q: What is the difference between data importer vs. data processor or data controller.

A: The roles of controller and processor are entirely distinct from the roles of data exporter and data importer. Controller/processor relates to the role played by the entity during the

processing activity. Data exporter and data importer relate to transfers of personal data – specifically which party exports and which party imports personal data.

The Standard Contractual Clauses apply when a party is transferring data to another party located outside the EEA. In the context of transfers, the party who transfers the personal data outside the EEA is a data exporter as they export the data. The party who is located outside the EEA and receives the personal data is the data importer as they import the data. The data importer can be a data processor or data controller. This depends on the services the data importer is providing.

14 Contact details from local law firms

Please also include radha.pulltergunne@dlapiper.com in cc when emailing local counsel.

Country	Name	Email address	Phone number
Belgium	Heidi Waem (Counsel)	heidi.waem@dlapiper.com	+32 2500 1614
France	Denise Lebeau-Marianna (Partner)	denise.lebeau-marianna@dlapiper.com	+ 33 (0)1 40 15 24 98
Germany	Jan Pohle (Partner)	Jan.pohle@dlapiper.com	+49 221 277 277 391
Italy	Giulio Corragio (Partner)	giulio.coraggio@dlapiper.com	+39 02 80 6181
Latvia	Ieva Andersone (Partner) Andis Burkevics (Counsel)	ieva.andersone@sorainen.com andis.burkevics@sorainen.com	+371 67 365 000 +371 67 365 007
Lithuania	Stasys Drazdauskas (Counsel) Irma Kirklytė (Senior Associate)	stasys.drazdauskas@sorainen.com irma.kirklyte@sorainen.com	+370 52 685 040 +370 52 685 040
The Netherlands	Richard van Schaik (Partner) Radha Pull ter Gunne (Junior Associate)	richard.vanschaik@dlapiper.com Radha.PullterGunne@dlapiper.com	+31 20 541 9828 +31 (0) 6 1363 5596
Poland	Ewa Kurowska-Tober (Partner) Magdalena Koniarska (Senior Associate)	ewa.kurowska-tober@dlapiper.com magdalena.koniarska@dlapiper.com	+48 22 540 74 1502 +48 22 540 78 19
Romania	Ana-Maria Andronic (Counsel) Corina Badiceanu (Managing Associate)	anamaria.andronic@dlapiper.com corina.badiceanu@dlapiper.com	+40 372 155 816 +40 372 155 853
Sweden	Jennie Nilsson (Partner)	jennie.nilsson@se.dlapiper.com	+46 73 867 67 87
United Kingdom	Andrew Dyson (Partner) Ross McKean (Partner)	andrew.dyson@dlapiper.com ross.mckean@dlapiper.com	+44 (0)113 369 2403 +44 (0) 20 7796 6077

15 Amendments to Manual & Templates for the creation of version 2.0

i. Error is amended on page 46, Annex 6 should be template record of processing activities

ii. We have added page number to the annex overview on page 25

iii. Amendments to the Privacy Notice for Applicants on pages 61 in section 3, reference to section 10 is replaced with a reference to section 9. In section 5.2 the reference to section 4 is replaced to a reference to section 3.

iv. On page 34, which is page 9 of the IHAG Personal Data Protection Policy, the following words are included: “or another country offering equivalent protection personal date is not allowed unless this ….”

v. A new template Co-worker photo and video consent form has been added (Annex 12, page 75), as well as an instruction page (page 13). A new bullet has been added to page 4 under “Templates”.

vi. A new template DSR tracker/privacy files has been added (Annex 14, page 92), as well as an instruction page (page 14).

vii. In the template Privacy Notice for Co-workers, a new purpose for ESG reporting is included under section 4, in the 6th row (“For the administration and operation of [insert name A]’s policies and procedures: (…) (c) collecting and compiling information on Co-workers for ESG reporting”) on page 54. We advise Privacy Champions to update the Privacy Notices for Co-workers accordingly.